

Bloc 2

Guide de lecture, preuves sélectionnées et documentation d'exploitation complète - hors limite des 30 pages du dossier

Pièce	Objet
B2-A20	Navigation publique, reflow, clavier et axe
B2-A25	Recette métier authentifiée et corrections
B2-A26	Playwright OAuth réel et stockage hors Git
B2-A27	Correction de l'audit des dépendances
B2-A28	Baseline main, CI, CD, OAuth et couvertures
B2-A29	Performance des healthchecks de production
B2-A30	Prototype final desktop/mobile et axe privé
B2-A31	Couverture autonome du package shared
B2-A34	Recettes métier finales et parcours journalisé
B2-A35	Recettes sécurité finales OWASP et navigateur
B2-A36	Audit accessibilité final public et privé
B2-A37	Zoom natif, contrastes et contre-recette
B2-A38	Preuve négative dynamique du blocage CI vers CD
GUIDE-01	Guide de lecture du jury
DOC-01	Manuel de déploiement complet
DOC-02	Manuel utilisateur complet
DOC-03	Manuel de mise à jour complet

Les pièces historiques restent dans le dépôt mais ne sont pas présentées comme preuves de la baseline finale.

Sommaire

GUIDE-01 - Guide de lecture du jury	3
B2-A20 - Recette navigateur et accessibilité publique du 2026-07-20	6
B2-A25 - Recette authentifiée de production et correctifs	8
B2-A26 - Playwright authentifié avec une session OAuth réelle	10
B2-A27 - Correction de nouveaux avis de sécurité des dépendances	12
B2-A28 - Validation de la baseline de consolidation, CI, CD et OAuth	13
B2-A29 - Mesure de performance des healthchecks de production	14
B2-A30 - Prototype authentifié desktop et mobile	15
B2-A31 - Couverture autonome du package shared	18
B2-A34 - Recettes métier finales - 2026-07-21	19
B2-A35 - Recettes de sécurité finales du 21 juillet 2026	23
B2-A36 - Audit accessibilité final public et authentifié	28
B2-A37 - Zoom natif, contrastes et contre-recette d'accessibilité	31
B2-A38 - Preuve négative CI/CD courante sur branche isolée	35
DOC-01 - Manuel de déploiement complet	37
DOC-02 - Manuel utilisateur complet	40
DOC-03 - Manuel de mise à jour complet	43

GUIDE-01 - Guide de lecture du jury

Lecture recommandée

1. Lire la synthèse et la matrice finale du dossier principal, sections 2 et 17.
2. Examiner en priorité les quatre compétences éliminatoires : C2.2.1, C2.2.2, C2.2.3 et C2.3.1.
3. Utiliser la matrice ci-dessous pour passer du critère à la preuve primaire.
4. Consulter le cahier de recettes pour distinguer les 58 scénarios clos de l'unique réserve CR-055.
5. Vérifier dans le MANIFESTE .txt du paquet que la source, les deux PDF et les empreintes appartiennent au même gel documentaire.

La décision d'acquisition appartient au jury. Les états « étayé » ci-dessous signifient seulement qu'une chaîne de preuves vérifiable est fournie.

Repères factuels

Repère	Valeur à vérifier
Compétences du bloc	9
Compétences éliminatoires	C2.2.1, C2.2.2, C2.2.3 et C2.3.1
Cahier de recettes	59 scénarios : 58 clos, 1 réservé
Baseline de production	b002adb
CI canonique	GitHub Actions 29845956008, six jobs verts
CD canonique	GitHub Actions 29846343559, smoke tests Web/API verts
Tests des suites complètes	shared 14, API 170, Web 55 ; périmètre PostgreSQL RNCP 9 contrôles
Accessibilité finale	33/33 contrôles, zoom natif 16/16 ; portée humaine non exhaustive
Documentation d'exploitation	manuel de déploiement, manuel utilisateur et manuel de mise à jour

Matrice des neuf compétences

Compétence	Ce que le jury doit pouvoir établir	Point d'entrée	Preuves primaires	État et limite
C2.1.1 - Environnements, qualité et performance	Les environnements et objectifs sont définis, reproductibles et mesurés.	Dossier, sections 3 et 5	B2-A21, B2-A22, B2-A28, B2-A29 ; docs/deployment.md	Étayé. A29 est une mesure séquentielle, pas un test de charge distribué.
C2.1.2 - Intégration continue	Chaque changement traverse des gates qualité, tests, audit, build et images.	Dossier, section 4	.github/workflows/ci.yml, B2-A23, B2-A27, B2-A28, B2-A38 ; CI 29845956008	Étayé. Les rapports séparent suites complètes et tests instrumentés pour la couverture.
C2.2.1 - Prototype fonctionnel	Les parcours essentiels fonctionnent sur une interface responsive et protégée.	Dossier, section 7	B2-A25, B2-A30, captures bureau/mobile, recette CR-065	Éliminatoire - étayé. La démonstration doit rester centrée sur les parcours réellement observés.
C2.2.2 - Tests unitaires	Les règles métier et composants critiques sont vérifiés avec des résultats mesurables.	Dossier, section 8	B2-A19, B2-A28, B2-A31 ; rapports de couverture	Éliminatoire - étayé. 155 API, 43 Web, 8 PostgreSQL et 14 shared sont instrumentés ; les suites complètes comptent 170 API, 55 Web, 9 PostgreSQL RNCP et 14 shared.
C2.2.3 - Sécurité, accessibilité et conformité	Les risques principaux ont des contrôles exécutés et les limites ne sont pas masquées.	Dossier, sections 9 et 10	B2-A23 à A30, B2-A35, B2-A36, B2-A37 ; revue OWASP	Éliminatoire - étayé avec limite humaine. Aucun audit RGAA exhaustif ni parcours avec lecteur d'écran réel n'est revendiqué.
C2.2.4 - Déploiement progressif et versionnement	Une baseline identifiée passe de la CI au CD avec migration et smoke tests.	Dossier, section 11	B2-A22, B2-A28, B2-A38 ; docs/ci-cd.md ; CD 29846343559	Étayé. b002adb est le SHA applicatif ; le SHA documentaire est distinct.
C2.3.1 - Cahier de recettes	Les exigences sont traduites en scénarios, résultats et preuves auditable.	Dossier, section 12	B2-A12, B2-A25, B2-A30, B2-A34 à A38	Éliminatoire - étayé avec une réserve. 58/59 clos ; seule CR-055 reste explicitement bornée.
C2.3.2 - Correction des bogues	Les anomalies sont reproduites, priorisées, corrigées et contre-testées.	Dossier, section 13	B2-A13, B2-A25, B2-A27, B2-A34, B2-A36 à A38	Étayé. Le registre distingue correction observée, automatisation et risque accepté.
C2.4.1 - Documentation d'exploitation	Un tiers peut déployer, utiliser et mettre à jour sans dépendre d'une explication orale.	Dossier, sections 14 à 16	Les trois manuels complets et B2-A22	Étayé. Les secrets et valeurs personnelles sont volontairement absents.

Réserve et contrôle CI/CD à lire avant l'oral

CR-055 - accessibilité humaine

Les contrôles automatisés, clavier, focus, reflow, arbre d'accessibilité et zoom natif sont consignés dans B2-A36 et B2-A37. Deux vérifications ne sont pas présentées comme accomplies : une revue humaine exhaustive des contrastes sur fonds composites et un parcours complet avec un lecteur d'écran réel. Cette réserve interdit de transformer les résultats axe/Playwright en déclaration de conformité RGAA exhaustive.

CR-062 - chemin négatif CI vers CD fermé par B2-A38

B2-A38 consigne la CI courante 29856584668, volontairement rouge sur la pull request brouillon isolée #46. Après l'échec ESLint, les jobs de tests, build, E2E et Docker sont skipped, aucun run CD n'est associé au SHA et les inventaires Vercel de production API/Web restent strictement inchangés. Le test `pnpm test:cd-policy` passe 6/6 contrôles sur le YAML courant. CR-062 est donc clos par cette preuve négative, le chemin vert 29845956008 vers 29846343559 et la preuve historique. Sa limite reste explicite : aucun commit volontairement rouge n'a été poussé sur main, afin de ne pas dégrader la branche de production.

Vérification d'intégrité

Deux identités coexistent volontairement :

- b002adb identifie le code applicatif effectivement testé et déployé ;
- le SHA documentaire inscrit dans le MANIFESTE . txt identifie la consolidation

et la source remises au jury, sans prétendre qu'elles ont été redéployées.

Le MANIFESTE . txt du paquet est la référence finale pour les SHA complets, le nombre de pages et les empreintes SHA-256. En cas de divergence entre une copie de travail et le paquet, le paquet manifesté prévaut.

B2-A20 - Recette navigateur et accessibilité publique du 2026-07-20

Compétences : C2.2.3 et C2.3.1

Version observée : 69b21ef-dirty, candidate locale 0.13.0-rc.1

Environnement : Windows, Node.js v24.14.0, Playwright 1.59.1

Périmètre réellement exécuté

Les contrôles ont été exécutés dans les navigateurs Playwright Chromium et Firefox. Le navigateur intégré Codex n'était pas disponible dans cette session (aucun navigateur détecté) : aucune inspection via ce navigateur n'est donc revendiquée.

Commandes finales réussies :

```
pnpm exec playwright test tests/e2e/browser-evidence.spec.ts --project=chromium --reporter=list
12 passed (43.1s)
```

```
pnpm exec playwright test tests/e2e/browser-evidence.spec.ts --project=firefox --reporter=list
12 passed (56.6s)
```

Une tentative ciblée supplémentaire sur /dashboard a expiré sans sortie pendant un conflit de build. Elle n'est ni conservée dans le test final ni comptée dans les 24 résultats ci-dessus.

Résultats observés

Pages publiques à 320 × 720 px

Route	HTTP	Largeur document Chromium/Firefox	Erreurs JS	Violations axe ciblées	Capture
/	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/login	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/confidentialite	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/cette-page-nexi ste-pas	404 attendu	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox

axe-core a été exécuté avec les tags wcag2a, wcag2aa, wcag21a et wcag21aa. Ce résultat automatisé ne constitue pas un audit RGAA manuel.

Chromium a journalisé une erreur console réseau pour la navigation HTTP 404 : Failed to load resource: the server responded with a status of 404 (Not Found). Firefox n'a pas émis ce message. Les deux JSON bruts conservent cette différence. Aucune pageerror JavaScript n'a été observée.

Clavier et focus

- sur /, /login et /confidentialite, la première touche Tab a focalisé le lien « Aller au contenu principal » dont la cible observée est #main-content ;
- après Entrée, l'élément actif observé est MAIN#main-content dans les deux navigateurs ; Chromium conserve le fragment dans l'URL, Firefox non ;
- le bouton de connexion a été focalisé et son nom accessible vérifié comme « Continuer avec Google » dans les deux navigateurs ;
- le fournisseur OAuth n'a pas été ouvert et aucune connexion n'a été tentée.

Protection sans session

Les routes /generate, /programs, /workouts et /settings ont réellement abouti à `http://localhost:3000/login` avec le titre de connexion attendu, dans Chromium et Firefox. /dashboard reste non exécuté dans cette annexe.

Anomalies détectées et corrections

1. Le lien d'évitement modifiait le fragment sans focaliser systématiquement le contenu. Correction : `tabIndex={-1}` sur `main#main-content`.
 2. La lettre décorative « G » était incluse dans le nom accessible du bouton Google. Correction : `aria-hidden="true"` sur ce décor.
 3. L'inspection des captures à 320 px a révélé un contraste visuellement faible sur la page de connexion et le pied de page. Correction : panneau sombre sur la zone de connexion et textes de pied de page assombris. Une mesure manuelle des ratios reste à effectuer avant de conclure sur le critère RGAA.
- Après ces corrections, les runs finaux séparés Chromium et Firefox sont ceux indiqués plus haut. Le typage Web et le lint Web ont également réussi.

Artefacts bruts

Le dossier `browser-evidence-2026-07-20/` contient 32 fichiers :

- 8 captures PNG, quatre routes dans deux navigateurs ;
- 8 JSON de page avec URL, statut HTTP, viewport, largeur, console, `pageerror` et violations axe ;
- 6 JSON clavier ;
- 2 JSON sur le bouton Google ;
- 8 JSON de redirection sans session.

Non exécuté - ne pas présenter comme preuve

- OAuth Google réel, création de session et déconnexion ;
- pages et composants authentifiés ;
- audit manuel RGAA complet, zoom 200/400 %, lecteur d'écran et technologies d'assistance ;
- mesure manuelle de tous les contrastes ;
- /dashboard dans cette recette instrumentée ;
- production et SHA final immuable.

B2-A25 - Recette authentifiée de production et correctifs

Date : 2026-07-20

Environnement : production Vercel/Neon

Navigateur : navigateur intégré Codex, session Google ouverte par le candidat

Versions observées : 0.13.0-rc.2, puis 0.13.0-rc.3

Périmètre et méthode

Le candidat a terminé lui-même la connexion Google, puis a indiqué que la session était disponible. La recette a été conduite dans cet onglet existant, sans lire ni exporter les cookies, le stockage local ou l'identité du compte. Les observations proviennent de l'arbre d'accessibilité, de l'URL, du focus actif et des journaux console du navigateur.

Cette annexe ne vaut pas audit RGAA humain complet et ne transforme pas les contrôles automatisés en preuve manuelle.

Recette métier initiale sur 0.13.0-rc.2

Parcours	Données et actions réellement exécutées	Résultat observé
Session	ouverture de /generate après connexion réalisée par le candidat	formulaire privé affiché, navigation privée et bouton de déconnexion présents
Validation séance	soumission vide	deux alertes anglaises String must contain at least 1 character(s)
Séance IA	sport Mobilite - recette RNCP, durée 15 min, objectif et contraintes explicitement marqués comme données de recette	séance créée sous l'ID 2a4d598f-48a7-4068-8219-49ac6660adaa, détail totalisant exactement 15 min
Timer séance	démarrage, attente, pause, attente 2,2 s, reprise, Échap	décompte actif, valeurs inchangées pendant la pause, reprise correcte ; après Échap le focus tombait sur BODY
Filtre séances	inspection du filtre Sport	liste fermée à huit sports alors que la génération accepte un texte libre
Programme IA	même sport de recette, 2 semaines, 2 séances/semaine, 20 min/séance	programme créé sous l'ID e1fdc5af-84fc-4114-8af6-046daadd5f0d, 2 semaines et 4 séances de 20 min
Onglets programme	ArrowRight, Home, End	sélection et focus conformes sur les deux semaines
Séance programme	ouverture de la séance 2-1	détail de 20 min et Timer affichés
Dashboard	lecture des statistiques du compte	données réelles affichées ; variantes Course a pied et Course à pied séparées
Paramètres	lecture puis enregistrement sans changement	fournisseur OpenAI serveur, modèle GPT-5.4 mini, confirmation de sauvegarde
Suppressions	Échap sur la confirmation puis confirmation effective	focus restauré après Échap ; seules les deux ressources de recette ci-dessus ont été supprimées

Aucune erreur console n'a été observée sur ces parcours. Après le nettoyage, la liste comptait de nouveau 12 séances et 4 programmes. Aucune autre donnée du compte n'a été supprimée.

Anomalies issues de cette exécution

ID	Anomalie réelle	Correction
B2-BUG-023	messages Zod anglais dans les deux formulaires français	messages explicites français dans les schémas partagés et HTTP
B2-BUG-024	focus perdu après sortie du plein écran Timer	restauration vers le contrôle Timer vivant après démontage du portail
B2-BUG-025	filtre Sport incompatible avec les sports libres	champ de recherche texte, formulaire GET et requête conservée
B2-BUG-026	variantes typographiques comptées séparément au dashboard	regroupement casse, accents et espaces avant tri et limite

La correction a été livrée par la PR [#34](#), fusionnée dans le SHA applicatif 3a21e3b2b547e99410388d5b83b62df79a436ea8.

Vérifications de 0.13.0-rc.3

Contrôle	Preuve	Résultat
Local	pnpm test, typecheck, lint, build, audit low	155 tests API et 43 tests Web réussis ; aucune vulnérabilité connue
CI de PR	run 29746856421	6 jobs réussis, couvertures, PostgreSQL, E2E public/axe et Docker inclus
CI main	run 29747228594	6 jobs réussis sur le SHA fusionné
CD	run 29747592571	migration, API, Web et smoke tests réussis
Healthchecks	API /health, /health/ready, Web /api/health	HTTP 200, version 0.13.0-rc.3, DB ok, configuration IA ok
Monitoring	run 29748032763	succès et artefact de monitoring produit
Validation séance vide	soumission réelle de /generate	Le sport ne peut pas être vide et L'objectif ne peut pas être vide
Validation programme vide	soumission réelle de /programs/generate	mêmes alertes françaises adaptées aux champs
Filtre libre	valeur Mobilite - recette RNCP, bouton Filtrer	URL ?sport=Mobilite+-+recette+RNCP&level=, valeur conservée, état Aucun resultat
Agrégation dashboard	lecture après déploiement	une entrée Course à pied à 2 au lieu de deux variantes à 1
Focus Timer	démarrage d'une séance existante puis Échap	élément actif BUTTON, texte Pause, aria-pressed=true, dialogue fermé
Déconnexion	bouton de déconnexion puis ouverture de /dashboard	redirection finale vers /login, lien Se connecter, aucun bouton de déconnexion

Aucun journal console n'a été observé durant la contre-recette rc.3.

Limites conservées

- les écrans Google de consentement n'ont pas été instrumentés : seule la session obtenue par le candidat et son fonctionnement ont été observés ;
- aucun cookie, token ou stockage de session n'a été inspecté ;
- il ne s'agit pas d'une suite Playwright authentifiée réutilisable avec storageState ;
- le lecteur d'écran, le zoom 200/400 %, les ratios de contraste exhaustifs et la recette mobile authentifiée restent à exécuter.

B2-A26 - Playwright authentifié avec une session OAuth réelle

Date : 2026-07-21

Environnement testé : `https://ai-sport-web.vercel.app`

Commit applicatif testé : `d149076e32b6e48c1bd0811060a5ad726451ed83`

Compétences : C2.2.1, C2.2.2, C2.2.3, C2.3.1 et C2.3.2

Objet de la preuve

Cette annexe ferme l'écart « suite Playwright authentifiée avec un `storageState` réel » relevé dans B2-A25. Elle ne repose ni sur une fixture vide, ni sur un cookie fabriqué, ni sur une interception de la route de session.

Le candidat a configuré une adresse comme identité du compte Google de test et a réalisé lui-même l'étape Google OAuth dans un Chrome système ouvert avec un profil temporaire. Le script a ensuite :

1. interrogé réellement `/api/auth/session` ;
2. refusé la capture si l'adresse `Auth.js` différait de l'identité attendue ;
3. conservé uniquement les cookies et origines du domaine exact `ai-sport-web.vercel.app` ;
4. vérifié la présence d'un cookie de session `Auth.js` ;
5. protégé le fichier local par ACL NTFS limitée à l'utilisateur courant ;
6. fermé Chrome et supprimé le profil temporaire.

L'adresse du compte et le contenu du `storageState` ne figurent pas dans Git. L'état local est sous `apps/web/playwright/.auth/`, chemin ignoré par `.gitignore`. Les trois cookies conservés appartenaient au seul domaine Alcide ; aucun cookie Google n'a été écrit dans le fichier.

Anomalies réellement détectées

Le premier workflow lancé sur main, run [29814300540](#), a restauré et utilisé la vraie session mais a terminé en échec : deux assertions anciennes ciblaient un champ interne caché et l'annonceur de route `Next.js` au lieu des éléments fonctionnels attendus.

Ces faux contrôles ont été remplacés par :

- l'inspection des champs visibles du formulaire nommé, après attente de son affichage ;
- des assertions sur les alertes de champ réelles, leur visibilité et leur message français.

Le filtrage du `storageState` possède aussi un test comportemental : un cookie Alcide est conservé, tandis qu'un cookie Google et un sous-domaine trompeur sont rejetés.

Résultats obtenus

Exécution locale contre la production

Commande :

```
pnpm test:e2e:authenticated
```

Résultat observé le 2026-07-21 après la correction des dépendances : **4 tests réussis sur 4** en 13,4 s. Chaque scénario vérifie d'abord que `/api/auth/session` retourne exactement l'identité configurée.

Les contrôles qualité exécutés avant publication ont aussi réussi :

- lint sans erreur ni avertissement ESLint ;
- typecheck des workspaces réussi ;

- 155 tests API et 43 tests Web réussis ;
- 3 tests de politique de session réussis.

GitHub Actions avec GitHub Secrets

- Workflow : E2E authentifié - compte Google dédié
- Run : [29816721099](#)
- Job : Parcours authentifié sans session personnelle
- Commit : d149076e32b6e48c1bd0811060a5ad726451ed83
- Conclusion : **success**

Faits visibles dans le journal du run :

- les secrets E2E_AUTH_EMAIL et E2E_AUTH_STORAGE_B64 sont présents ;
- l'identité est masquée par GitHub dans la sortie ;
- la session est restaurée dans un fichier hors suivi Git ;
- Running 4 tests using 1 worker puis 4 passed (5.5s) ;
- l'étape de suppression de la session du runner réussit ;
- le job complet réussit en 51 s.

Limites conservées

- Le caractère exclusivement dédié du compte relève de la gouvernance du candidat ; le contrôle technique prouve l'identité configurée, pas les usages passés du compte Google.
- La connexion sur les écrans Google reste manuelle, Google refusant le navigateur directement automatisé ; Playwright intervient après le retour OAuth sur Alcide.
- Le workflow couvre quatre scénarios sur /generate. Il ne constitue pas un audit RGAA humain, un test mobile authentifié ou une recette exhaustive de toutes les routes privées.
- La session Auth.js expire et doit alors être recapturée puis remplacée dans GitHub Secrets. Aucun mot de passe Google n'est stocké par le projet.

B2-A27 - Correction de nouveaux avis de sécurité des dépendances

Date : 2026-07-21

Commit testé : d149076e32b6e48c1bd0811060a5ad726451ed83

Compétences : C2.1.2, C2.2.3 et C2.3.2

Anomalie détectée

Le run CI [29815728217](#) a échoué dans le job Security audit avec quatre vulnérabilités high :

- trois branches de brace-expansion, avis

[GHSA-3jxr-9vmj-r5cp](#) ;

- shell-quote 1.8.4, avis

[GHSA-395f-4hp3-45gv](#).

Ces avis de déni de service ont été publiés dans la base GitHub Advisory le 2026-07-20. Ils n'étaient donc pas couverts par la preuve historique B2-A23. Aucune exploitation n'a été observée ; l'échec provient du contrôle bloquant `pnpm audit --audit-level=low`.

Correction appliquée

Les overrides transitifs ont été limités aux plages vulnérables et remplacés par les premières versions publiées corrigées :

Dépendance	Versions corrigées utilisées	Dépendances parentes observées
brace-expansion	1.1.16, 2.1.2 et 5.0.7	minimatch 3, 9 et 10
shell-quote	1.9.0	concurrently et gel/drizzle-orm

La version 1.8.5 de shell-quote, initialement mentionnée par la sortie d'audit comme borne corrigée, n'existe pas dans le registre npm. Elle n'a pas été inventée ni ajoutée au lockfile : la première version corrigée publiée selon l'avis GitHub est 1.9.0.

Vérifications réelles

Les commandes locales suivantes ont réussi :

```
pnpm install --frozen-lockfile
pnpm audit --audit-level=low
pnpm exec concurrently "node --version" "node --version"
pnpm lint
pnpm typecheck
pnpm test
pnpm build
```

Résultats : aucune vulnérabilité connue, smoke concurrently réussi, 155 tests API et 43 tests Web réussis, build de production réussi.

La CI de PR [29816347653](#) a ensuite terminé avec les six jobs verts : audit de sécurité, lint/typecheck, tests et couvertures avec PostgreSQL, E2E public/accessibilité, builds des packages et images Docker.

Limite

Les avis de dépendances évoluent après chaque gel. Cette preuve décrit l'état du registre et du lockfile le 2026-07-21 ; le job bloquant doit rester actif pour détecter les avis ultérieurs.

B2-A28 - Validation de la baseline de consolidation, CI, CD et OAuth

Date : 2026-07-21

Baseline de consolidation avant le correctif final de reflow : 0d5c6b6041333e2b756e59cb5d4440cc7ef7128b

Version annoncée par les services : 0.13.0-rc.3

Baseline canonique après correctif de reflow : b002adb0e0e7d8d85ee493d54879e190d77d2078, CI 29845956008, CD 29846343559

Chaîne réellement exécutée

Contrôle	Exécution	Résultat
CI complète main	run 29832575391	6 jobs réussis
Migration et CD Vercel	run 29832944876	migration, API, Web et smoke tests réussis
Playwright OAuth	run 29833210488	6/6 scénarios réussis en 9,8 s
Playwright accessibilité du lot	exécution locale sur la production 0d5c6b6	33/33 sur 3 pages publiques et 5 privées
Web health	GET https://ai-sport-web.vercel.app/api/health	HTTP 200, status=ok
API readiness	GET https://ai-sport-api.vercel.app/health/ready	HTTP 200, DB ok, IA ok

La CI a exécuté lint, typecheck, tests de politiques, 170 tests API, 55 Web, 14 shared, couvertures, tests PostgreSQL, Playwright public et axe, builds de production, audit de dépendances et images Docker. Le CD n'a démarré qu'après le succès de la CI.

Artefacts de couverture détaillée du run antérieur 29817362423

Les métriques ci-dessous ont été extraites du premier run consolidé et restent conservées pour leur granularité. Le run de consolidation 29832575391 republie les quatre rapports après l'ajout des recettes finales.

Les artefacts suivants ont été listés puis téléchargés depuis GitHub Actions :

- coverage-report-api ;
- coverage-report-web ;
- coverage-report-api-integration ;
- playwright-report.

L'analyse des fichiers lcov.info donne :

Rapport	Lignes	Branches	Fonctions
API unitaire	1 038/1 212 - 85,64 %	197/245 - 80,41 %	62/65 - 95,38 %
Web	2 804/4 061 - 69,05 %	405/520 - 77,88 %	110/136 - 80,88 %
API intégration PostgreSQL	431/460 - 93,70 %	52/65 - 80 %	16/16 - 100 %

Le package shared ne disposait pas encore d'un rapport autonome dans ce run. Cette lacune est corrigée et prouvée séparément dans B2-A31.

Protection de la session OAuth

Le run authentifié restaure le storageState depuis GitHub Secrets, vérifie l'identité Auth.js attendue, n'enregistre aucune session Google et supprime le fichier du runner avant la publication du rapport. Les logs masquent l'identité. Le fichier local reste exclu de Git et protégé par les droits du seul utilisateur Windows.

Cette annexe prouve la chaîne technique observée, sans prouver l'usage historique exclusif du compte Google ni un audit RGAA humain. Elle conserve la preuve de la consolidation 0d5c6b6 : le correctif de reflow postérieur ne modifie ni le protocole CI/CD, ni les couvertures, ni le parcours OAuth. La baseline applicative finalement déployée est b002adb, validée par la CI 29845956008, le CD 29846343559, le zoom natif 16/16 et la contre-recette d'accessibilité 33/33 détaillés dans B2-A37.

B2-A29 - Mesure de performance des healthchecks de production

Date UTC : 2026-07-21 de 09:36:34 à 09:37:07

Poste : environnement candidat Windows, réseau réel

Script : scripts/measure-production-health.mjs

Protocole

Le script a envoyé 50 requêtes séquentielles sans préchauffage et sans authentification vers chacun des trois endpoints. Une réponse n'est valide que si HTTP est réussi et si le JSON contient le statut attendu.

Objectif défini avant lecture des résultats :

- 100 % de réponses HTTP/JSON valides ;
- p95 inférieur ou égal à 1 000 ms par endpoint.

Commande :

```
node scripts/measure-production-health.mjs 50
```

Résultats bruts synthétisés

Endpoint	Succès	Minimum	Médiane	p95	Maximum	Moyenne	Objectif
Web /api/health	50/50	172,00 ms	195,12 ms	508,63 ms	552,93 ms	227,09 ms	atteint
API /health	50/50	167,91 ms	194,00 ms	339,66 ms	491,55 ms	216,42 ms	atteint
API /health/ready	50/50	169,46 ms	191,51 ms	267,11 ms	276,33 ms	199,70 ms	atteint

Total : 150 réponses valides sur 150 et trois objectifs p95 atteints.

Portée et limites

La readiness exerce réellement la connexion PostgreSQL et vérifie la présence de la configuration IA. Cette mesure ne remplace pas un test de charge, ne représente qu'un point réseau et ne mesure pas une génération OpenAI. Les erreurs fournisseur, retries et timeouts sont couverts par les tests API ; une génération réelle de production est consignée dans B2-A25 sans durée chiffrée conservée.

B2-A30 - Prototype authentifié desktop et mobile

Date : 2026-07-21
Production : <https://ai-sport-web.vercel.app>
Session : Auth.js réelle, fichier local hors Git

Méthode

Le script `apps/web/scripts/capture-rncp-prototype.mjs` ouvre Chromium avec le `storageState` Alcide déjà contrôlé, charge les formulaires privés en production et capture uniquement la zone principale. Il n'affiche ni adresse électronique ni donnée personnelle. Le profil mobile utilise un viewport de 390 x 844 px et le script échoue en cas de débordement horizontal.

La suite `apps/web/tests/e2e/generate.spec.ts` a ensuite exécuté six scénarios authentifiés sur la production :

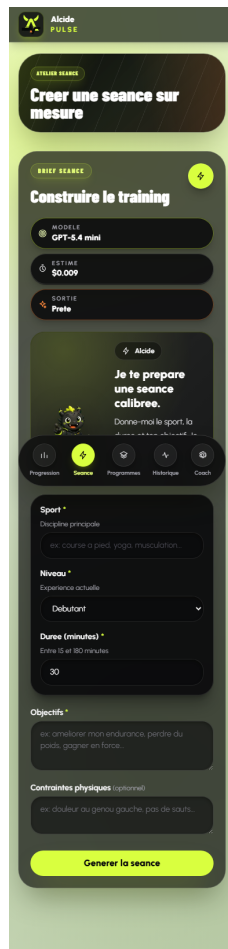
- 1. formulaire privé accessible après connexion ;
- 2. labels associés à tous les champs ;
- 3. erreur explicite sur le sport vide ;
- 4. erreurs de formulaire annoncées avec `role=alert` ;
- 5. utilisation à 390 px sans débordement horizontal ;
- 6. aucune violation axe critique ou sérieuse sur le formulaire privé.

Résultat local : 6/6 en 15,7 s.

Le workflow distant a ensuite exécuté la même suite sur le commit `81b2b0bd6afa0cf3a33cca6d7ee045ae5808709d` : run GitHub Actions [29820498452](#), 6/6 en succès. La session dédiée a été restaurée depuis GitHub Secrets, utilisée uniquement pour le domaine Alcide, puis supprimée du runner.

Captures et empreintes

Capture	Dimensions	SHA-256
génération séance desktop	1440 x 992	A2E6530CA4E189359641F1CA611A4F99A7D0C3F6010E629FC0B81F9AB239443C
génération programme desktop	1440 x 1101	2CB08B244579FCB3546173E10459536819268E43943E8122957E4336F7FD6E97
génération séance mobile	390 x 1634	481517A35F7AD80E0A7B186681A88790F8372CFC046DA5D61AB68002532E79BC



Génération d'une séance à 390 px

Limite

Le contrôle mobile et axe est automatisé. Il ne remplace pas le zoom manuel, les contrastes exhaustifs ou la restitution par un lecteur d'écran.

B2-A31 - Couverture autonome du package shared

Date : 2026-07-21

Commit technique : 81b2b0bd6afa0cf3a33cca6d7ee045ae5808709d

CI de pull request : [run 29819423534](#)

Écart corrigé

Les contrats shared étaient exercés indirectement depuis les tests API, mais ne disposaient ni d'une suite autonome ni d'un rapport de couverture séparé. Le dossier ne pouvait donc pas chiffrer honnêtement ce périmètre.

Harnais ajouté

La suite `packages/shared/tests/schemas.test.ts` couvre :

- cohérence de la durée détaillée d'une séance ;
- bornes des formulaires séance et programme ;
- numérotation des semaines et séances ;
- nombre de semaines et de séances ;
- durée annoncée et durée détaillée des programmes ;
- références autorisées pour un journal de séance simple ou de programme.

Commande :

```
pnpm --filter shared test:coverage
```

Résultat local et CI

Indicateur	Résultat
Fichiers de test	1/1 réussi
Tests	14/14 réussis
Statements	100 %
Lignes	100 %
Fonctions	100 %
Branches	92,85 %

Le job `Unit tests and coverage` du run 29819423534 a réussi et a publié l'artefact `coverage-report-shared`. La CI continue de publier séparément les rapports API, Web et PostgreSQL ; les taux ne sont pas fusionnés artificiellement.

Les fichiers de types TypeScript sans code runtime sont compilés par `tsc` et ne sont pas inclus dans le taux V8 des schémas exécutables.

B2-A34 - Recettes métier finales - 2026-07-21

Compétence : C2.3.1 - cahier de recettes.

Exécution : 21 juillet 2026, de 14 h 23 à 14 h 40 (Europe/Paris).

Révision de départ : bac3b916770cabbbc92e3cda0d58ac3ed7e5e119.

Baseline du lot de recettes métier testée et déployée : correctifs fusionnés par la PR 43 dans

0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, puis CI 29832575391, CD

29832944876 et E2E OAuth 29833210488 réussis.

Baseline canonique après le correctif de reflow, sans modification de ces règles métier :

b002adb0e0e7d8d85ee493d54879e190d77d2078, CI 29845956008, CD 29846343559.

Repère documentaire final : tag rncp-bloc2-2026-07-21-v7.

Le SHA effectivement archivé est porté par le manifeste du paquet de remise.

1. Environnements et données

Couche	Environnement réellement utilisé
API/Web local	Windows, Node 24.14.0, pnpm 11.9.0, Vitest et build Next.js
PostgreSQL	conteneur local postgres:16-alpine, base de test sur localhost:5432
Parcours authentifié	https://ai-sport-web.vercel.app, Chromium Desktop Chrome, session OAuth réelle dédiée et non versionnée
Identité	l'adresse du compte de recette a été dérivée de /api/auth/session pour vérifier la session, sans être imprimée dans les sorties

Les tests PostgreSQL créent deux comptes aléatoires et les suppriment en fin de suite. Le parcours de production utilise uniquement le compte OAuth de recette.

2. Anomalies corrigées pendant la recette

CR-038 - modèle OpenAI non autorisé accepté

L'API acceptait toute chaîne commençant par gpt-, alors que l'interface ne propose que trois modèles. Un appel direct pouvait donc persister une valeur non autorisée.

Correctif dans apps/api/src/controllers/settings.controller.ts :

- liste fermée gpt-5.4-mini, gpt-5.4, gpt-5.5 ;
- validation Zod avant tout appel au repository ;
- repli sur gpt-5.4-mini à la lecture d'une ancienne valeur inconnue ;
- test HTTP : réponse 400 BAD_REQUEST et zéro appel à upsertSettings.

CR-030/CR-034 - revalidation de la page courante après journalisation

Une tentative de production a montré que la revalidation de la page Timer pouvait remonter le composant avant que la confirmation de sauvegarde reste visible. La séance et le programme ne changent pas lors de la création d'un journal ; seule la donnée du dashboard doit être invalidée.

Correctif dans les deux pages de séance :

- conservation de revalidatePath('/dashboard') ;
- suppression de la revalidation de la page Timer courante ;
- conservation de la revalidation de la fiche programme parente pour une séance issue d'un programme.

3. Résultats par scénario

ID	Exécution et preuve	Résultat
CR-013	simulations OpenAI 429, 503 et timeout de 45 000 ms ; test HTTP 503, absence d'appel à createWorkout ; test UI du message et de la réutilisation du formulaire	Réussi sur la candidate par simulation déterministe
CR-018	page 2/2 rendue côté Web ; paramètres page=2, limit=1 et user Id transmis ; PostgreSQL réel avec trois programmes du propriétaire et un programme d'un autre compte	Réussi, pagination et isolation confirmées
CR-021	suppression programme en erreur 500 ; message conservé par l'API et confirmation UI maintenue ouverte avec alerte	Réussi
CR-030	création HTTP d'un journal avec durée active 487 s ; PostgreSQL réel ; parcours production Timer puis enregistrement	Réussi
CR-034	note facultative normalisée puis stockée sous l'identité authentifiée ; page Confidentialité vérifiée ; note de recette saisie en production	Réussi
CR-035	annulation, Échap, restauration du focus et panne API testés pour une séance ; confirmation maintenue ouverte	Réussi
CR-037	changement local autorisé ; en production, changement, rechargement et lecture de la valeur persistée, puis restauration de la valeur initiale dans un bloc finally	Réussi, aucun réglage temporaire laissé
CR-038	valeur gpt - modele - interdit envoyée à l'API locale candidate	Réussi : 400, aucune persistance
CR-040	dashboard rendu avec zéro séance et zéro journal	Réussi : état « Aucune activité encore », explication et CTA /generate
CR-041	rendu de totaux connus (4, 3, 1 h 30, effort 6.5/10), agrégation sport ; PostgreSQL réel isolé ; production après journalisation	Réussi
CR-065	session OAuth validée, page Programmes ouverte, séance existante ouverte, toutes les phases Timer passées, effort/feedback/note saisis, journal sauvegardé puis dashboard relu	Réussi : compteur « Terminé » de 3 à 4

4. Commandes et sorties conservées

Les commandes ci-dessous ont été lancées avec le runtime Node fourni par l'espace de travail. Aucun secret ni cookie n'a été affiché.

Tests ciblés métier

```
pnpm --filter api exec vitest run \
  tests/rncp-ai-unavailability-recipes.test.ts \
  tests/rncp-business-recipes.test.ts
```

```
Test Files 2 passed (2)
Tests      9 passed (9)
```

```
pnpm --filter web exec vitest run components/rncp-business-recipes.test.tsx
```

```
Test Files 1 passed (1)
Tests      9 passed (9)
```

Suites complètes et PostgreSQL

```
pnpm --filter api test
```

```
Test Files 19 passed (19)
Tests      170 passed (170)
```

```
pnpm --filter web test
```

```
Test Files 14 passed (14)
```

```
Tests          55 passed (55)
$env:TEST_DATABASE_URL='postgresql://alcide:alcide_dev@localhost:5432/alcide'
pnpm --filter api test:integration

Test Files     1 passed (1)
Tests          8 passed (8)
```

Cette suite PostgreSQL contient notamment : pagination et suppression des programmes sans exposition inter-compte, journalisation d'une source détenue, stockage de painNotes, statistiques exactes et statistiques vides pour l'autre compte.

Les sorties ci-dessus sont celles des suites complètes : 170 tests API et 55 tests Web. Les rapports de couverture correspondants instrumentent 155 tests API et 43 tests Web. Pour PostgreSQL, 8 tests sont instrumentés dans le rapport de couverture ; la recette de sécurité SQL indépendante porte le total RNCP à 9. La suite shared compte 14 tests dans les deux présentations.

Qualité et compilation

```
pnpm typecheck
packages/shared: Done
apps/api: Done
apps/web: Done

pnpm lint
apps/api: Done
apps/web: No ESLint warnings or errors

pnpm build
shared: tsc réussi
api: tsc réussi
web: Next.js – Compiled successfully, 13/13 pages générées
```

Production authentifiée

Commande assainie :

```
PLAYWRIGHT_AUTH_STORAGE=<fichier local ignoré par Git>
E2E_AUTH_EMAIL=<valeur dérivée de la session, non affichée>
E2E_BASE_URL=https://ai-sport-web.vercel.app
pnpm --filter web exec playwright test \
  --config=playwright.rncp-recipes.config.ts
```

Résultats utiles :

```
CR-037 : passed (4.6 s), modèle initial restauré
CR-030/034/041/065 : passed (14.5 s)
[RNCP CR-065] dashboard 3 -> 4; formulaire=confirmation-visible
```

5. Traçabilité honnête des tentatives

Trois exécutions du parcours authentifié ont eu lieu :

1. la première s'est arrêtée avant l'envoi du journal, car le clic Playwright visait l'input radio visuellement masqué ; aucune donnée n'a été créée par cette tentative ;
2. la deuxième a atteint l'envoi, puis l'assertion a échoué parce que `getByRole( ' status ' )` correspondait à trois éléments. Elle a pu créer un journal, mais l'incrément du dashboard n'a pas été mesuré pendant cette tentative ;
3. la dernière exécution a mesuré explicitement 3 -> 4 et constitue la preuve de clôture retenue.

Il n'existe pas d'interface de suppression des journaux. Le journal final - et éventuellement celui de la deuxième tentative - reste donc dans le compte de recette. Les champs contiennent uniquement les marqueurs de test suivants :

- douleur: Recette RNCP : gene legere temporaire, donnee de test.;
- notes: Parcours final automatise du 2026-07-21..

6. Limites

- CR-013 a été couvert par simulations reproductibles 429, 503 et timeout ; aucune panne réelle d'OpenAI n'a été provoquée en production.
- CR-018 et l'isolation multi-compte de CR-041 ont été exécutés sur PostgreSQL local réel, pas avec deux comptes OAuth de production.
- CR-040 est une recette de rendu déterministe avec données vides simulées ; le compte de production n'est plus vide.
- CR-065 valide une session OAuth existante et visite les objets déjà présents ; il ne rejoue pas l'écran Google ni une nouvelle génération OpenAI.
- Le verrouillage CR-038 et les suppressions de revalidation ont été intégrés à

la baseline 0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, puis ont passé la CI 29832575391, le CD 29832944876, les smoke tests et la contre-recette OAuth 29833210488. Le correctif de reflow ultérieur n'a pas modifié ce périmètre métier ; la baseline canonique b002adb a ensuite passé la CI 29845956008 et le CD 29846343559. Leur déploiement final n'est donc plus à confirmer.

7. Pièces techniques

- apps/api/tests/rncp-ai-unavailability-recipes.test.ts
- apps/api/tests/rncp-business-recipes.test.ts
- apps/web/components/rncp-business-recipes.test.tsx
- apps/web/tests/e2e/rncp-recipes-final.spec.ts
- apps/web/playwright.rncp-recipes.config.ts
- apps/api/src/controllers/settings.controller.ts
- apps/web/app/workouts/[id]/page.tsx
- apps/web/app/programs/[id]/sessions/[sessionId]/page.tsx

Conclusion : les onze scénarios du lot métier disposent maintenant d'une preuve exécutée. Les limites de production ci-dessus ne sont pas converties en preuves plus fortes qu'elles ne le sont.

B2-A35 - Recettes de sécurité finales du 21 juillet 2026

Objet et conclusion

Cette annexe consigne la fermeture non destructive des recettes de sécurité CR-042, CR-043, CR-045, CR-046 et CR-047. Elle complète la revue OWASP pour les catégories A02, A03, A04, A05 et A09.

Les contrôles automatisés et les observations de production sont concluants :

- 6/6 tests API en mémoire et 1/1 test d'intégration PostgreSQL réussis ;
- 1/1 test de rendu React hostile réussi ;
- 6/6 tests Playwright réussis dans Chromium et Firefox, puis 3/3 Chromium après le durcissement de la collecte des ressources ;
- 0 vulnérabilité connue retournée par `pnpm audit --audit-level low` ;
- 0 sink DOM dangereux, 0 appel DB non paramétré recherché et 0 clé OpenAI longue dans les fichiers suivis ;
- production Web et API disponibles en HTTPS ;
- CORS de production refusé à une origine hostile et accordé uniquement au front officiel ;
- 0 occurrence des marqueurs de secrets recherchés dans le HTML et les neuf scripts JavaScript chargés par la page de production.

Aucun défaut applicatif nécessitant un correctif de production n'a été trouvé pendant cette campagne. Les ajouts sont des tests de non-régression et la présente preuve. Le risque résiduel principal est la présence de `'unsafe-inline'` dans `script-src` et `style-src` ; `'unsafe-eval'` est bien absent de la CSP de production.

Périmètre et environnement

Élément	Valeur contrôlée
Date et heure de fin des observations	2026-07-21, 14:26 CEST / 12:26 UTC
Révision de base locale	bac3b916770cabbbc92e3cda0d58ac3ed7e5e119 (main)
Baseline de la campagne sécurité	0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, CI/CD réussies
Baseline canonique déployée	b002adb0e0e7d8d85ee493d54879e190d77d2078, CI 29845956008, CD 29846343559
État local	révision de base avec tests et documents RNCP non commités
Système	Windows NT 10.0.22631
Node.js	24.14.0
pnpm	11.9.0
Vitest	3.2.6
Playwright	1.59.1
Navigateurs	Chromium et Firefox fournis par Playwright
PostgreSQL local	16.14 dans le conteneur alcide-db
Web local	Next.js démarré automatiquement sur <code>http://localhost:3000</code>
Web officiel observé	<code>https://ai-sport-web.vercel.app</code>
API officielle observée	<code>https://ai-sport-api.vercel.app</code>

Les tests API de CORS, headers et refus d'authentification utilisent l'instance Hono en mémoire. Le test CR-042 distinct utilise PostgreSQL local, crée un utilisateur jetable, insère et relit la charge via le repository, vérifie la table puis supprime l'utilisateur par cascade. Aucun test n'appelle OpenAI ou OAuth. Les requêtes de production sont uniquement des GET, HEAD ou pré-requêtes OPTIONS.

Le passage de 0d5c6b6 à b002adb corrige uniquement le reflow de composants Web. Il ne modifie pas les contrôles de sécurité testés ici ; la CI canonique a néanmoins rejoué l'ensemble des jobs avant le CD final.

Résultat par scénario

ID	Contrôle exécuté	Résultat observé	Statut
CR-042	Compilation du prédicat Drizzle avec <code>' ; DROP TABLE workouts; --</code>	la requête contient un placeholder \$1, le texte n'apparaît pas dans le SQL et reste dans params	Fermé
CR-042	Insertion et relecture via le repository sur PostgreSQL 16.14	la chaîne exacte est relue dans la colonne et le JSONB ; workouts reste requêtable ; nettoyage vérifié à 0 utilisateur de test	Fermé
CR-042	Validation HTTP Zod avec chaînes SQL-like et dépassement de borne	la chaîne bornée reste une donnée ; un objectif de 501 caractères est rejeté	Fermé
CR-043	Rendu d'un titre <code><script></code> et d'un sport <code></code> dans WorkoutCard	texte visible mais aucun nœud script ou image hostile, aucun attribut d'exécution modifié	Fermé
CR-043	Payload XSS contrôlé dans l'URL, Chromium et Firefox	aucune exécution et aucune réflexion brute dans le HTML	Fermé
CR-045	Inspection HTML et scripts dans deux navigateurs locaux	aucun nom ou valeur sentinelle de secret, aucun motif de clé sk - * longue	Fermé
CR-045	Inspection de la production officielle	HTML de 54 578 caractères et 9 scripts ; 0 OPENAI_API_KEY, SERVICE_SECRET, AUTH_SECRET, AUTH_GOOGLE_SECRET et clé sk - * longue	Fermé
CR-046	Pré-requête locale avec <code>Origin: https://hostile.rncp.test</code>	HTTP 204 sans Access-Control-Allow-Origin	Fermé
CR-046	Pré-requête de production avec une origine hostile	HTTP 204 sans Access-Control-Allow-Origin	Fermé
CR-046	Pré-requête de production avec le front officiel	HTTP 204 avec Access-Control-Allow-Origin: <code>https://ai-sport-web.vercel.app</code>	Fermé
CR-047	Headers effectifs dans Chromium et Firefox	CSP, nosniff, DENY, referrer policy et permissions policy présents	Fermé
CR-047	Headers du Web de production	HSTS, CSP complète, nosniff, DENY, referrer policy et permissions policy présents ; 'unsafe-eval' absent	Fermé avec risque résiduel documenté

Détail des contrôles OWASP

A02 - Défaillances cryptographiques

- Les URL HTTP du Web et de l'API répondent 308 Permanent Redirect vers HTTPS.
- Le Web retourne ``Strict-Transport-Security: max-age=63072000; includeSubDomains; preload``.
- L'API retourne ``Strict-Transport-Security: max-age=15552000; includeSubDomains``.
- Le navigateur ne reçoit aucun des marqueurs de secrets serveur recherchés.
- Le module d'appel API reste importé avec `server-only` et injecte le secret interservice uniquement côté serveur.

A03 - Injection

Le test compile le même prédicat `eq(workouts.sport, valeur)` utilisé par les repositories. Même avec la charge textuelle `' ; DROP TABLE workouts; --`, le texte reste dans le tableau des paramètres et n'est pas concaténé au SQL. Une recherche complémentaire ne trouve ni `sql.raw()` ni `db.execute()` dans `apps/api/src`, et aucun usage de `dangerouslySetInnerHTML`, affectation à `innerHTML`, `eval()` ou `new Function()` dans le code applicatif.

La charge exacte a ensuite été envoyée au PostgreSQL local uniquement comme paramètre du repository Drizzle. Elle a été relue sans altération dans la colonne `sport` et le JSONB. Une requête `SELECT` exécutée après l'insertion a confirmé que `workouts` restait utilisable. Le nettoyage par suppression de l'utilisateur de test a laissé 0 utilisateur `rnnp-security-*` et 0 séance dans cette base locale. Aucune requête de suppression issue de la charge n'a été exécutée et la production Neon n'a pas été modifiée.

A04 - Conception non sécurisée

- Zod revalide les données au contrôleur HTTP, indépendamment de la validation du formulaire Web.
- Les limites sont vérifiées : la charge SQL-like bornée est une donnée valide, tandis qu'un champ dépassant 500 caractères est rejeté.
- Les tests n'appellent aucun fournisseur externe et n'augmentent aucune charge de production.
- Le refus d'accès aux routes privées reste effectué avant tout accès à la base lorsque le secret interservice est invalide.

A05 - Mauvaise configuration de sécurité

Le Web de production retourne notamment :

```
Content-Security-Policy: default-src 'self';
script-src 'self' 'unsafe-inline';
style-src 'self' 'unsafe-inline';
img-src 'self' data: https;;
font-src 'self';
connect-src 'self' https://ai-sport-api.vercel.app;
object-src 'none'; base-uri 'self'; form-action 'self';
frame-ancestors 'none'; upgrade-insecure-requests
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
```

L'API de production ajoute entre autres `Cross-Origin-Opener-Policy: same-origin`, `Cross-Origin-Resource-Policy: same-origin, nosniff, HSTS` et `Cache-Control: no-store, max-age=0` sur `/health`.

A09 - Journalisation et surveillance

Le test d'accès privé avec un secret contrôlé invalide obtient HTTP 401. Le serveur émet l'événement `[Auth] Secret interne invalide` ou manquant avec le chemin `/workouts`. Le corps client contient uniquement l'erreur générique `UNAUTHORIZED` et n'expose ni la valeur envoyée, ni le secret attendu, ni une stack trace.

Cette preuve porte sur la génération et la séparation serveur/client des logs. Elle ne revendique pas une plateforme centralisée de corrélation, d'alerte et de rétention des journaux.

Commandes reproductibles et sorties synthétiques

Tests API et rendu React

```
pnpm --filter api exec vitest run tests/rncp-security-final.test.ts
## 1 fichier réussi ; 6 tests réussis

docker start alcide-db
$env:TEST_DATABASE_URL = `
  'postgresql://alcide:alcide_dev@127.0.0.1:5432/alcide'
pnpm --filter api exec vitest run --config vitest.rncp-security.config.ts
## 1 fichier réussi ; 1 test PostgreSQL réussi (4.39s)
docker exec alcide-db psql -U alcide -d alcide -tAc `
  "select count(*) from users where email like 'rncp-security-%@alcide.test';"
## 0
docker exec alcide-db psql -U alcide -d alcide -tAc `
  "select count(*) from workouts;"
## 0 dans cette base locale après cleanup
docker stop alcide-db

pnpm --filter web exec vitest run components/rncp-security-final.test.tsx
## 1 fichier réussi ; 1 test réussi
```

L'avertissement indiquant que OPENAI_API_KEY est absente est attendu dans le test API : aucune route de génération n'est appelée.

Tests navigateur

```
pnpm --filter web exec playwright test tests/e2e/rncp-security-final.spec.ts
## Running 6 tests using 2 workers
## 6 passed (48.9s)

pnpm --filter web exec playwright test `
  tests/e2e/rncp-security-final.spec.ts --project=chromium
## rejeu après attente déterministe des corps de réponse : 3 passed (33.7s)
```

Les trois scénarios sont exécutés une fois sous Chromium et une fois sous Firefox : XSS URL, absence de secrets navigateur et headers/CSP effectifs.

Audit des dépendances et recherches ciblées

```
pnpm audit --audit-level low
## No known vulnerabilities found

rg -n "dangerouslySetInnerHTML|\.innerHTML\s*=\|beval\(|new Function\(" `
  apps packages --glob '!*/*.test.*' --glob '!*/.next/**' `
  --glob '!*/node_modules/**'
## aucune occurrence

rg -n "sql\.raw\(|db\.execute\(" apps/api/src --glob '*.ts'
## aucune occurrence

git grep -I -n -E "sk-[A-Za-z0-9_-]{20,}" -- . ':!pnpm-lock.yaml'
## aucune occurrence
```

CORS et headers de production

```
curl.exe -sS -D - -o NUL -X OPTIONS `
  https://ai-sport-api.vercel.app/health `
  -H "Origin: https://hostile.rncp.test" `
  -H "Access-Control-Request-Method: GET"
## 204 ; aucun Access-Control-Allow-Origin

curl.exe -sS -D - -o NUL -X OPTIONS `
  https://ai-sport-api.vercel.app/health `
  -H "Origin: https://ai-sport-web.vercel.app" `
  -H "Access-Control-Request-Method: GET"
## 204 ; Access-Control-Allow-Origin: https://ai-sport-web.vercel.app

curl.exe -sS -D - -o NUL https://ai-sport-web.vercel.app/
curl.exe -sS -D - -o NUL https://ai-sport-api.vercel.app/health
## 200 pour les deux services ; headers décrits ci-dessus
```

Inspection des ressources navigateur de production

```
$base = 'https://ai-sport-web.vercel.app'
$html = (curl.exe -sS "$base/" | Out-String)
$scripts = [regex]::Matches($html, '<script[^>]+src="(["]+)"') |
    ForEach-Object { $_.Groups[1].Value } | Sort-Object -Unique
$parts = foreach ($source in $scripts) {
    $url = if ($source.StartsWith('http')) { $source } else { "$base$source" }
    curl.exe -sS $url | Out-String
}
$surface = $html + [string]::Join("`n", $parts)
## HTML_CHARS=54578 ; SCRIPT_COUNT=9
## OPENAI_API_KEY=0 ; SERVICE_SECRET=0 ; AUTH_SECRET=0
## AUTH_GOOGLE_SECRET=0 ; LONG_SK_PATTERN=0
```

Fichiers de preuve ajoutés

- apps/api/tests/rncp-security-final.test.ts ;
- apps/api/tests/rncp-security-final.integration.test.ts ;
- apps/api/vitest.rncp-security.config.ts ;
- apps/web/components/rncp-security-final.test.tsx ;
- apps/web/tests/e2e/rncp-security-final.spec.ts ;
- docs/rncp/bloc2-annexes/B2-A35-recettes-securite-finales-2026-07-21.md.

Limites et risque résiduel

1. La chaîne contenant DROP TABLE est compilée puis persistée comme donnée dans PostgreSQL local. Elle n'est jamais exécutée comme SQL et n'est pas envoyée à Neon ; la preuve ne simule donc aucune attaque sur la production.
2. Le test XSS couvre le sink React d'une carte alimentée par une valeur persistée et la non-réflexion URL dans deux vrais navigateurs. Il ne crée pas de séance en production et n'engendre aucun coût OpenAI.
3. L'inspection de secrets est une recherche déterministe de noms, valeurs sentinelles et formats de clés connus dans les ressources effectivement chargées ; elle ne remplace pas un gestionnaire de secrets ni une rotation.
4. Le refus CORS protège les navigateurs. Un client serveur n'est pas soumis à CORS ; l'authentification interservice reste donc le contrôle principal des routes privées.
5. La CSP autorise encore 'unsafe-inline' pour les scripts et styles requis par l'implémentation Next.js actuelle. Une CSP à nonce ou hash constitue un durcissement futur. En revanche, 'unsafe-eval' est absent en production, object-src vaut 'none' et frame-ancestors vaut 'none'.
6. La preuve A09 vérifie la génération d'un événement et l'absence de fuite client ; l'observabilité centralisée et les alertes restent un chantier MCO distinct.

B2-A36 - Audit accessibilite final public et authentifie

Date d'execution : 2026-07-21

Application observee : <https://ai-sport-web.vercel.app>

Source locale au debut du controle : bac3b916770cabbbc92e3cda0d58ac3ed7e5e119

Contre-recette après déploiement du correctif de reflow : 33/33 et zoom natif

16/16 sur b002adb0e0e7d8d85ee493d54879e190d77d2078, après CI 29845956008

et CD 29846343559.

Repère documentaire final : tag rncp-bloc2-2026-07-21-v7.

Le SHA effectivement archivé est porté par le manifeste du paquet de remise.

Referentiel de travail : RGAA 4.1.2 et WCAG 2.1 A/AA

Statut : preuves renforcees, conforme RGAA exhaustive non revendiquee

Objet et perimetre

Cette campagne ferme les controles automatisables restes ouverts sur un echantillon public et prive : reflow CSS, complete par un zoom Chromium natif a 200 % et 400 % dans B2-A37, parcours clavier, visibilite du focus, contrastes calculables, structure et annonces exposees aux technologies d'assistance.

Pages publiques testees :

- / ;
- /login ;
- /confidentialite.

Pages privees testees avec une vraie session Auth.js locale :

- /dashboard ;
- /generate ;
- /programs ;
- /workouts ;
- /settings.

Un controle navigateur authentifie independant a aussi couvert /programs/generate. Les champs hidden ajoutes par Next.js pour les Server Actions ont ete exclus des controles de labels : ils ne sont ni visibles, ni modifiables, ni atteignables au clavier.

Protection de la session

Le storageState OAuth utilise est un fichier local ignore par Git et non suivi. La configuration dediee desactive traces, captures et videos pour eviter d'enregistrer des cookies ou des donnees de compte. Le test verifie uniquement la presence d'un cookie de session Auth.js sans imprimer son nom complet, sa valeur, l'adresse electronique ou le contenu du fichier.

Methode reproductible

La suite dediee se trouve dans apps/web/tests/e2e/rncp-accessibility-final.spec.ts et sa configuration dans apps/web/playwright.rncp-accessibility.config.ts. Elle a ete executee avec Chromium et Playwright, en production, avec un worker unique :

```
$env:PLAYWRIGHT_AUTH_STORAGE='<chemin local ignore par Git>'
$env:E2E_BASE_URL='https://ai-sport-web.vercel.app'
npm --filter web exec playwright test --config=playwright.rncp-accessibility.config.ts
```

Les controles sont les suivants :

1. reflow a 640 pixels CSS, approximation de mise en page d'un viewport bureau de 1280 pixels zoome a 200 % ;

2. reflow a 320 pixels CSS, approximation de mise en page du meme viewport zoome a 400 % ;
3. parcours Tab complet de toutes les commandes visibles, jusqu'a la sortie du document, avec comparaison a l'inventaire des elements tabulables ;
4. verification de : focus-visible et d'un indicateur perceptible, par contour ou ombre de focus, a chaque etape ;
5. regle color-contrast d'axe sans filtrage par severite, completee par le calcul sRGB du ratio texte/fond du bouton principal opaque ;
6. inspection de l'arbre d'accessibilite Chromium par CDP : RootWebArea, main, navigation et au moins un titre nomme ;
7. declenchement des erreurs de /generate et controle des regions role="alert".

L'inspection CDP est une lecture de l'arbre d'accessibilite. Elle ne constitue pas un test avec un lecteur d'ecran.

Resultats Playwright

Résultat post-déploiement : **33 tests réussis sur 33**, en 58,7 secondes.

Controle	Pages	Resultat
Reflow 640 et 320 pixels CSS	3 publiques + 5 privees	8/8, aucun scrollwidth superieur au viewport
Cycle clavier complet et focus visible	3 publiques + 5 privees	8/8, aucune commande omise, aucun piege detecte
Contrastes	3 publiques + 5 privees	8/8 tests sans violation axe ; mesure representative conforme
Arbre d'accessibilite	3 publiques + 5 privees	8/8, racine, contenu principal, navigation et titre exposes
Erreurs dynamiques	/generate	erreurs de champs exposees avec role="alert"

Le controle navigateur authentifie independant a confirme l'absence de debordement horizontal sur /generate, /programs/generate, /workouts, /dashboard et /settings a 640 x 720 puis 320 x 720 pixels. Les largeurs de document relevees etaient respectivement 625 et 305 pixels, donc inferieures a la largeur utile du viewport. Aucun identifiant HTML duplique n'a ete trouve sur les etats stabilises.

Le rejeu du 2026-07-21 a de nouveau lance les **33 tests** sur la production avec la session OAuth locale et s'est termine avec le code 0. Le zoom natif a ete rejoue separement sur les huit routes : **16/16 mesures**, facteur obtenu 2x puis 4x, aucun debordement horizontal et aucun texte ou controle rogne.

Contrastes mesures

Les ratios sRGB du texte sur le fond opaque du bouton principal sont :

Pages	Ratio minimal mesure	Seuil AA texte normal
/, /login, /confidentialite	17,36:1	4,5:1
/dashboard, /generate, /programs, /workouts, /settings	8,19:1	4,5:1

Axe a mesure en plus 1 texte sur /, 2 sur /login, aucun sur /confidentialite ni sur le dashboard vide, 1 sur /generate, 4 sur /programs, 10 sur /workouts et 1 sur /settings. Aucune violation de la regle color-contrast n'a ete renvoyee.

Chaque page conserve toutefois **une verification axe incomplete** en raison des fonds composites, transparences ou images. Les ratios ci-dessus sont donc des mesures representatives, pas une mesure exhaustive de chaque texte, et ne

suffisent pas a declarer une conformite RGAA complete.

Le script `scripts/rncp-a11y-contrast-sampling.ps1` a ensuite regroupe les 416 occurrences par cause axe, couleurs CSS, fond, graisse, corps et seuil WCAG. Il produit **79 signatures de rendu**, dont **34 P1** et **45 P2**, et **166 contextes route-signature**. Ce tri rend la revue humaine bornée et reproductible ; toutes les signatures conservent le statut `human_review_required` tant qu'un operateur n'a pas saisi le ratio mesure, sa decision et la preuve.

Structure et annonces

Les huit pages de l'echantillon exposent dans l'arbre d'accessibilite une racine de document, une region principale, une navigation nommee et au moins un titre. Sur `/generate`, l'envoi du formulaire vide rend visibles plusieurs erreurs, dont `#input-sport-error` et `#goals-error`, chacune exposee avec `role="alert"`.

Le controle independant a detecte deux h1 sur `/generate` et `/programs/generate` : un titre de page et un titre de formulaire. Le titre de chaque formulaire a ete corrige en h2 dans `WorkoutForm.tsx` et `ProgramForm.tsx`. Le test de non-regression `apps/web/components/rncp-accessibility-structure.test.tsx` verifie que les deux titres internes restent de niveau 2 et continuent de nommer leur formulaire. Resultat : **2 tests reussis sur 2**. Cette correction a ete integree a la baseline `0d5c6b6041333e2b756e59cb5d4440cc7ef7128b`, puis verifiee par la CI `29832575391`, le CD `29832944876` et la contre-recette de production `33/33`.

Anomalies et corrections

Identifiant	Observation	Action	Etat
B2-A36-01	Deux h1 sur chacune des pages de generation	Titres internes passes en h2 et test de non-regression ajoute	Corrige et contre-recette en production 33/33
B2-A36-02	Axe ne peut pas calculer les contrastes composites	Audit detaille rejoue : 0 violation, 19 nœuds calcules conformes et 416 nœuds incomplets regroupes en 79 signatures ; revue humaine requise	Partiellement couvert, voir B2-A37
B2-A36-03	Aucun lecteur d'ecran reel utilise pendant cette campagne	Narrator disponible, NVDA absent ; grille operateur prete pour une restitution documentee	Ouvert : aucune ecoute realisee
B2-A36-04	Limite historique : le reflow initial reposait uniquement sur des viewports CSS	Audit natif à 200/400 %, détection puis correction des troncatures de métriques et cartes	Clos : correctif <code>b002adb</code> déployé, zoom natif production 16/16, voir B2-A37

Conclusion et limites

Les sous-contrôles reflow, clavier, focus visible, structure de l'arbre et annonces d'erreur sont couverts sur l'echantillon. Les contrastes opaques representatifs respectent largement le seuil AA et aucune violation axe n'est remontee.

Le scenario d'accessibilite ne doit cependant pas etre marque entierement clos tant que les points suivants ne sont pas realises et consignés :

- verification manuelle des contrastes composites signales incomplete ;
- parcours avec un vrai lecteur d'ecran, par exemple NVDA ou Narrator.

En particulier, **aucun test NVDA, Narrator, JAWS ou VoiceOver n'a ete realise** ici. L'arbre d'accessibilite Chromium apporte une preuve structurelle utile, mais ne permet pas de conclure sur la qualite de la restitution vocale ni sur le confort d'usage reel. Le statut global reste donc « conforme RGAA non determinee », sans revendication de conformite exhaustive.

B2-A37 - Zoom natif, contrastes et contre-recette d'accessibilité

Date d'exécution : 2026-07-21

Production observée : <https://ai-sport-web.vercel.app>

Chromium : 147.0.7727.15

Playwright : 1.59.1

Baseline corrective déployée : b002adb0e0e7d8d85ee493d54879e190d77d2078

CI : 29845956008 - succès ; CD Vercel : 29846343559 - succès

Statut : anomalie de reflow corrigée et contre-recettée en production ; contrastes composites et lecteur d'écran réel encore ouverts

1. Rejeu complet public et authentifié

La suite `rncp-accessibility-final.spec.ts` a été rejouée avec une vraie session OAuth locale, ignorée par Git et jamais imprimée dans les sorties.

Contre-recette après déploiement : **33 tests réussis sur 33 en 58,7 secondes** sur les routes suivantes :

- publiques : `/`, `/login`, `/confidentialite` ;
- privées : `/dashboard`, `/generate`, `/programs`, `/workouts`, `/settings`.

Les contrôles couvrent le reflow 640/320 pixels CSS, le cycle clavier, la visibilité du focus, `color-contrast`, l'arbre d'accessibilité Chromium et les alertes du formulaire de génération.

Un nouveau rejeu le 2026-07-21 a lancé les **33 tests** sur la même production et s'est terminé avec le code 0. Les traces, captures et vidéos sont restées désactivées afin de ne pas enregistrer la session.

2. Zoom navigateur natif à 200 % et 400 %

Le test `apps/web/scripts/e2e-native-zoom-audit.mjs` charge une extension Chromium locale réservée à l'audit. Elle applique le zoom natif avec `chrome.tabs.setZoom`, puis contrôle le facteur réellement obtenu, le `devicePixelRatio`, la largeur CSS, les débordements et les éléments textuels rognés. Aucun cookie ni identifiant n'est consigné.

L'audit initial de la production précédente a exécuté **16 mesures sur 16** : huit routes multipliées par les deux niveaux de zoom. Le facteur obtenu valait bien 2 puis 4, sans débordement horizontal global. Le contrôle renforcé a toutefois détecté quatre échecs à 400 % :

Route	Texte visuellement rogné
<code>/login</code>	libellé Séances d'une métrique
<code>/dashboard</code>	libellés Facile et Dosé
<code>/programs</code>	titres longs des cartes programme
<code>/workouts</code>	titres longs des cartes séance

Cause : les composants `MetricPill`, `ProgramCard` et `WorkoutCard` utilisaient la classe Tailwind `truncate`, donc `overflow: hidden` et une ellipse sans retour à la ligne.

Correctif : remplacement de la troncature par `break-words` et un interligne compact. Résultats après correction :

- **55 tests Web sur 55** ;
- typecheck réussi ;
- build Next.js réussi ;
- **6 mesures sur 6** sur les pages publiques de la version locale ;
- **16 mesures sur 16** sur une prévisualisation corrective, sans texte ni commande rognés ;
- CI 29845956008 entièrement verte sur le commit `b002adb` ;
- CD Vercel 29846343559 réussi : migration, API, Web et smoke tests ;

- **16 mesures sur 16 sur la production corrigée**, sans prévisualisation,

avec zoom Chromium natif à 200 % et 400 % ;

- **33/33 tests d'accessibilité de production** après déploiement.

Les rapports avant correction, de prévisualisation et de contre-recette sont séparés sous tmp/accessibility-final/native-zoom/ afin de ne pas les confondre. Le rapport post-déploiement est native-zoom-production.json.

Le contrôle a été rejoué le 2026-07-21 à 16:56:26Z sur Chromium 147.0.7727.15. Résultat : **16/16 mesures**, facteurs réels 2× et 4×, devicePixelRatio cohérent, contenu principal et titre visibles, aucun débordement horizontal, aucun texte ni contrôle rogné sur les huit routes.

3. Contrastes opaques et composites

Le script apps/web/scripts/e2e-contrast-incomplete-audit.mjs a rejoué la règle axe color-contrast sur les huit routes avec la session réelle :

- **0 violation** ;
- 416 nœuds classés incomplete : 331 à cause de gradients, 69 à cause de pseudo-éléments, 15 textes trop courts et un élément recouvert.

Le rejeu du 2026-07-21 à 16:55:46Z, avec Chromium 147.0.7727.15, confirme le même résultat route par route : **0 violation, 19 nœuds calculés et classés conformes, 416 nœuds incomplete**. Le rapport JSON temporaire ne contient ni cookie ni identité de compte.

Ces 416 occurrences ne sont pas 416 non-conformités : elles indiquent qu'axe ne peut pas calculer automatiquement le fond composite final. Les mesures opaques représentatives déjà consignées dans B2-A36 restent conformes, mais la revue visuelle exhaustive des fonds composites n'est pas déclarée close.

3.1 Préqualification reproductible des composites

Le script scripts/rncp-a11y-contrast-sampling.ps1 transforme le rapport détaillé en une liste de contrôle JSON et CSV :

```
powershell.exe -NoProfile -ExecutionPolicy Bypass -File `
.\scripts\rncp-a11y-contrast-sampling.ps1
```

Le regroupement exclut volontairement le texte littéral, le sélecteur et la route de sa clé. Une signature correspond à une même cause axe, aux mêmes couleurs et fonds CSS, à la même typographie et au même seuil WCAG. Chaque route concernée conserve cependant son propre contexte à vérifier.

Résultat du tri	Valeur
Occurrences axe incomplete	416
Signatures de rendu distinctes	79
Contextes route-signature à revoir	166
Signatures P1	34, soit 74 contextes
Signatures P2	45, soit 92 contextes
Gradients	331 occurrences
Pseudo-éléments	69 occurrences
Textes trop courts pour axe	15 occurrences
Élément recouvert	1 occurrence (Routine active, page /)

Les priorités P1 couvrent notamment les textes atténués au seuil 4,5:1, les pseudo-éléments et l'élément recouvert. P1/P2 ordonnent la revue ; elles ne qualifient pas à elles seules une non-conformité. Les fichiers produits sont contrast-review-sampling.json et contrast-review-sampling.csv, sous tmp/accessibility-final/contrast/. Ils ne contiennent ni cookie ni identité.

Ce tri ne clôt aucune signature automatiquement. Pour chaque contexte, un opérateur doit mesurer le pixel composite le plus défavorable, renseigner le ratio, la décision et la preuve, puis contre-recetter les corrections éventuelles.

4. Lecteur d'écran

La détection locale en lecture seule donne l'état suivant :

Outil	Disponibilité constatée	Portée réelle
Narrator	Présent : C:\Windows\System32\Narrator.exe, version 10.0.22621.6133	Lecteur utilisable par un opérateur ; aucune écoute réalisée
NVDA	Absent des emplacements système usuels et non trouvé comme commande	Aucun essai NVDA possible sur ce poste sans installation
Magnifier	Présent, même version de fichier que Narrator	Utile au grossissement visuel, pas à la restitution vocale
Gestion des couleurs Windows	ColorCpl.exe présent	Ne mesure pas le contraste texte/fond d'une page Web

Le contrôle de l'arbre d'accessibilité Chromium est réussi sur les huit routes ; il ne remplace pas un parcours humain capable de juger l'ordre, les annonces et le confort d'écoute.

Aucun test réel NVDA, Narrator, JAWS ou VoiceOver n'est donc revendiqué.

4.1 Grille Narrator/NVDA prête à exécuter

Préconditions opérateur : navigateur à 100 %, son actif, langue française, session de test sans données sensibles et captures limitées aux anomalies. Avec Narrator, démarrer ou arrêter par Windows + Ctrl + Entrée. Pour chaque ligne, consigner navigateur, lecteur et version, heure, données affichées, résultat, verbatim utile de l'annonce et chemin de preuve.

ID	Parcours et points d'écoute obligatoires	Résultat	Preuve/anomalie
SR-01	/login : langue, titre, ordre, nom/rôle du bouton et absence de répétition parasite	À renseigner	À renseigner
SR-02	/dashboard : lien d'évitement, main, navigation nommée, ordre et lien courant	À renseigner	À renseigner
SR-03	/generate vide : label, aide, requis, valeur et annonce immédiate des erreurs	À renseigner	À renseigner
SR-04	Génération valide : attente, erreur API éventuelle, résultat et maintien du focus	À renseigner	À renseigner
SR-05	Programme, onglets et séance : titres, nom/état, contenu actif et liens distincts	À renseigner	À renseigner
SR-06	/workouts : filtre, nombre ou état de résultats et lecture de la chronologie	À renseigner	À renseigner
SR-07	Timer : commandes, temps sans bavardage et changements status/live	À renseigner	À renseigner
SR-08	/settings : label/champ, option sélectionnée et confirmation ou erreur	À renseigner	À renseigner
SR-09	Suppression : titre, focus initial, piège, retour du focus et annonce finale	À renseigner	À renseigner
SR-10	Déconnexion : nom de l'action, changement de page, focus et titre de destination	À renseigner	À renseigner

Critère de fermeture : les dix lignes doivent être décidées par un opérateur, les anomalies reliées au plan de correction, puis rejouées après correctif. Un simple lancement de Narrator sans écoute consignée ne satisfait pas ce critère.

5. Décision de clôture

Le reflow natif a désormais une méthode reproductible. Le défaut découvert est corrigé, déployé et contre-recetté : B2-A36-04 et B2-BUG-034 sont clos. Il reste à traiter séparément :

1. la vérification humaine exhaustive des fonds composites ;
2. un parcours avec un lecteur d'écran réel et la consignation de la restitution.

La conformité RGAA exhaustive reste non revendiquée.

6. Matrice de décision

Contrôle	Méthode réellement exécutée	Résultat	Décision
Reflow CSS	Playwright à 640/320 pixels	8/8 routes sans débordement	Clos sur l'échantillon
Zoom navigateur réel	Extension locale et <code>chrome.tabs.setZoom</code> à 200/400 %	16/16, aucun rognage	Clos sur l'échantillon
Clavier et focus	Inventaire tabulable et cycle Tab	8/8 routes	Clos sur l'échantillon
Structure exposée	Arbre AX Chromium et tests de titres	8/8 routes et 2/2 tests	Clos structurellement
Contrastes calculables	axe color-contrast et ratios sRGB	0 violation, 19 passes	Clos pour les nœuds calculables
Contrastes composites	axe signale 416 incomplète, regroupés en 79 signatures (34 P1, 45 P2)	liste de revue produite, aucune décision humaine exhaustive	Ouvert
Restitution vocale	Narrator présent et grille SR-01 à SR-10 prête	aucune écoute consignée	Ouvert

Cette matrice distingue un résultat automatisé positif d'une appréciation humaine. Elle ne transforme ni un résultat incomplète ni l'arbre AX en preuve de conformité avec un lecteur d'écran.

B2-A38 - Preuve négative CI/CD courante sur branche isolée

Date : 2026-07-21

Compétences : C2.1.2, C2.2.4, C2.3.1 et C2.3.2

Scénario : CR-062 - empêcher tout déploiement de production après une CI rouge

Objectif et garde-fous

Le test devait provoquer un échec réel de la CI courante sans pousser de commit défaillant sur main et sans modifier la production. Une branche isolée et une pull request brouillon, explicitement non fusionnable, ont donc été utilisées :

- branche : codex/rncp-cd-gate-proof-v7 ;
- commit volontairement rouge : ef393f873ce3337c4ba83b84cf75eb5ce07549b4 ;
- pull request brouillon #46, fermée après collecte des preuves ;
- unique défaut injecté : variable TypeScript inutilisée dans un fichier de

preuve temporaire, soit une erreur @typescript-eslint/no-unused-vars.

Le test ne modifie ni la branche main, ni les migrations, ni les secrets, ni les applications de production.

Résultat GitHub Actions

Contrôle	Résultat observé
CI courante	run 29856584668, événement pull_request, conclusion failure
Job fautif	Lint and typecheck 88722310839, échec à l'étape ESLint après installation, build shared et typecheck réussis
Audit sécurité	job 88722310861, succès
Tests unitaires et couverture	job 88722490150, skipped
Build packages	job 88722490096, skipped
E2E smoke et accessibilité	job 88722489720, skipped
Build Docker	job 88722490652, skipped
Runs associés au SHA	un seul run : CI - Alcide 29856584668 ; aucun run CD - Vercel

Le workflow de production écoute uniquement les fins de CI dont la branche de tête est main. Une CI rouge de pull request n'engendre donc aucun workflow CD. Cette absence est un résultat attendu de la politique, pas un job CD présenté à tort comme skipped.

Inventaire Vercel production avant/après

L'inventaire a été lu avec Vercel CLI 54.17.2, filtre --environment production --format json, avant la création de la PR puis après la fin de la CI rouge.

Projet	Dernier déploiement production avant	Dernier déploiement production après	Décision
API ai-sport-api	ai-sport-beo6pvdnl-kevinmrgts-projects.vercel.app, READY, créé à 1784650955064, SHA b3ca385c0014c6acfd5c29ebbe14fa38ca766c02	valeurs strictement identiques	aucun nouveau déploiement production
Web ai-sport-web	ai-sport-hbjk1xwvs-kevinmrgts-projects.vercel.app, READY, créé à 1784651047559, SHA b3ca385c0014c6acfd5c29ebbe14fa38ca766c02	valeurs strictement identiques	aucun nouveau déploiement production

La vérification concerne la cible production. La preview Web de la pull request est restée distincte et ne constitue pas un déploiement production.

Test automatique de non-contournement

Le script `scripts/cd-workflow-policy.test.mjs` exécute six contrôles :

1. déclencheur `workflow_run` sur CI - Alcide, branche `main`, type `completed` ;
2. absence de `workflow_dispatch` dans le CD ;
3. conditions `conclusion == 'success'` et `ENABLE_GHA_VERCEL_CD == 'true'` sur `migrate-db`, `deploy-api` et `deploy-web` ;
4. checkout du `head_sha` exact de la CI pour chaque job ;
5. simulation `failure`, `cancelled` et `skipped` : décision de déploiement fausse ;
6. tests mutants : détection d'un déclencheur manuel ou du retrait de la gate.

Résultat local : **6/6 réussis**. Le contrôle est ajouté à la CI par la commande `pnpm test:cd-policy`.

Conclusion et portée

CR-062 est fermé par combinaison de preuves :

- chemin positif de production 29845956008 vers 29846343559 ;
- ancienne preuve `main rouge` 28506873066 vers CD 28506912686 `skipped` ;
- CI rouge courante réellement exécutée sur une PR isolée, aucun run CD associé ;
- inventaires Vercel production API/Web inchangés avant/après ;
- six tests de politique sur le YAML courant.

La limite est conservée : aucun commit volontairement rouge n'a été poussé sur `main`, car cette manipulation dégraderait inutilement la branche et pourrait perturber les utilisateurs. Le dossier ne prétend donc pas avoir reproduit ce risque destructif à l'identique.

DOC-01 - Manuel de déploiement complet

Production canonique

Composant	Plateforme	URL
Frontend	Vercel	https://ai-sport-web.vercel.app
API	Vercel	https://ai-sport-api.vercel.app
Base de données	Neon PostgreSQL	via DATABASE_URL

La CI/CD est documentée dans docs/ci-cd.md.

Variables d'environnement Vercel

Projet Web:

```
NEXT_PUBLIC_API_URL=https://ai-sport-api.vercel.app
SERVICE_SECRET=<same value as API>
AUTH_SECRET=<Auth.js secret>
AUTH_GOOGLE_ID=<Google OAuth client id>
AUTH_GOOGLE_SECRET=<Google OAuth client secret>
NEXTAUTH_URL=https://ai-sport-web.vercel.app
```

Projet API:

```
DATABASE_URL=<Neon pooled PostgreSQL URL>
SERVICE_SECRET=<same value as Web>
OPENAI_API_KEY=<OpenAI API key gérée par Alcide cote serveur>
FRONTEND_URL=https://ai-sport-web.vercel.app
NODE_ENV=production
```

GitHub Actions

1. CI - Alcide vérifie lint, types, tests et couvertures API/Web/PostgreSQL, build, smoke E2E public, audit dès le niveau low, politique de déploiement Vercel et Docker.
2. CD - Vercel se lance uniquement après une CI verte sur main si la variable GitHub `ENABLE_GHA_VERCEL_CD=true` est définie. Il n'existe plus de lancement manuel contournant les gates.
3. CD - Vercel applique les migrations Drizzle avant le déploiement API ; un échec bloque ensuite l'API et le Web. DB - Drizzle migrations reste un chemin manuel de reprise, rattaché à l'environnement production. Au relevé du 2026-07-20, cet environnement ne possédait aucune règle de protection ni approbateur ; ce n'est donc pas encore une gate humaine.
4. Les previews Vercel de pull request restent actives. Pour `VERCEL_ENV=production`, `ignoreCommand` ignore le déploiement automatique de l'intégration Git ; le workflow CD force explicitement le chemin canonique après CI verte.

Secrets GitHub requis pour la CD:

```
VERCEL_TOKEN
VERCEL_ORG_ID
VERCEL_API_PROJECT_ID
VERCEL_WEB_PROJECT_ID
DATABASE_URL
```

Le token doit autoriser `vercel pull/build/deploy` sur les deux projets. Le run CD canonique 29846343559, déclenché automatiquement après la CI 29845956008, a réussi sur le SHA `b002adb0e0e7d8d85ee493d54879e190d77d2078` : migration, API, Web et smoke tests de production. Les productions automatiques de l'intégration Git sont annulées par `ignoreCommand`, puis une seule production GitHub Actions aboutit par projet. Les runs 29747228594 et 29747592571 restent des preuves historiques du même protocole avant la correction finale de reflow.

Deploiement manuel Vercel

Cette procédure est réservée au diagnostic ou à une intervention d'urgence autorisée. Elle ne doit pas servir à contourner la CI ni à constituer la preuve de la candidate RNCP ; le chemin nominal reste le workflow CD après CI verte.

Depuis la racine du depot:

```
pnpm install --frozen-lockfile
pnpm build
```

API:

```
cd apps/api
vercel pull --yes --environment=production
vercel build --prod
vercel deploy --prebuilt --prod
```

Web:

```
cd apps/web
vercel pull --yes --environment=production
vercel build --prod
vercel deploy --prebuilt --prod
```

Migrations Neon

Dans le chemin nominal, le job migrate-db du workflow CD - Vercel applique les migrations avant le déploiement API. Pour une reprise autorisée ou une migration isolée, lancer le workflow manuel DB - Drizzle migrations.

En local, uniquement si DATABASE_URL pointe volontairement vers la cible:

```
pnpm install --frozen-lockfile
pnpm db:migrate
```

Verification post-déploiement

```
curl https://ai-sport-api.vercel.app/health
curl https://ai-sport-api.vercel.app/health/ready
curl https://ai-sport-web.vercel.app/api/health
curl -I https://ai-sport-web.vercel.app
```

Checklist:

- [x] CI verte sur le SHA applicatif livré
- [x] Migrations Drizzle appliquées par la CD
- [x] SERVICE_SECRET cohérent côté Web et API, prouvé par les smoke tests service-to-service
- [x] OAuth Google démarre avec le callback `https://ai-sport-web.vercel.app/api/auth/callback/google`
- [x] API liveness et readiness HTTP 200 après déploiement
- [x] Web healthcheck HTTP 200 après déploiement
- [x] Génération d'une séance testée avec un compte authentifié, puis donnée de recette supprimée (B2-A25)
- [x] Génération d'un programme testée avec un compte authentifié, puis donnée de recette supprimée (B2-A25)
- [x] run CI automatique vert sur la baseline applicative livrée (29845956008)
- [x] run CD automatique vert sur la baseline applicative livrée (29846343559)
- [x] zoom natif 200/400 % contre-recetté en production, 16/16, puis suite

d'accessibilité rejouée, 33/33

Alternative Docker Compose

Pour une demonstration locale ou un auto-hebergement:

```
cp .env.example .env
## Remplacer OPENAI_API_KEY, SERVICE_SECRET et les secrets OAuth de démonstration.
docker compose up -d postgres
docker compose --profile tools run --rm migrate
docker compose --profile tools run --rm seed # facultatif
docker compose up --build -d
```

Les commandes de migration et de seed utilisent des services outillage basés sur le stage Docker builder. Elles ne sont pas exécutées dans l'image API de production, qui ne contient volontairement ni drizzle-kit, ni tsx, ni les sources TypeScript.

URLs locales:

Service	URL
Web	http://localhost:3000
API	http://localhost:3001
PostgreSQL	localhost:5432

Alternative Fly.io pour l'API

Le fichier apps/api/fly.toml reste disponible. Depuis la racine:

```
fly deploy --config apps/api/fly.toml --remote-only .
```

Secrets Fly requis:

```
DATABASE_URL
OPENAI_API_KEY
SERVICE_SECRET
FRONTEND_URL=https://ai-sport-web.vercel.app
NODE_ENV=production
```

DOC-02 - Manuel utilisateur complet

1. Présentation

Alcide est une application web de coaching sportif assisté par IA. Elle permet à un utilisateur connecté de générer des séances ou programmes sportifs personnalisés, de les consulter, de suivre une séance avec timer et d'observer sa progression.

Public cible :

- sportif débutant, intermédiaire ou avancé ;
- coach ou utilisateur souhaitant préparer rapidement une séance ;
- jury RNCP pendant la démonstration.

2. Accéder à l'application

1. Ouvrir l'application web.
2. Depuis la page d'accueil, cliquer sur le bouton de connexion.
3. Choisir la connexion Google.
4. Autoriser l'application.
5. Après connexion, l'utilisateur accède aux fonctionnalités protégées.

Si l'utilisateur tente d'accéder directement à une page protégée sans session, il est redirigé vers la page de connexion.

3. Générer une séance d'entraînement

1. Aller sur la page Générer ou /generate.
2. Renseigner le sport souhaité.
3. Choisir le niveau.
4. Indiquer la durée.
5. Décrire les objectifs ou contraintes.
6. Valider le formulaire.

Résultat attendu :

- les champs invalides affichent un message d'erreur ;
- une demande valide crée une séance ;
- l'utilisateur est redirigé vers le détail de la séance.

En cas d'erreur IA ou serveur, un message d'erreur est affiché à l'utilisateur et la génération peut être relancée.

4. Générer un programme

1. Aller sur la page de génération de programme.
2. Renseigner l'objectif sportif.
3. Choisir le niveau, la durée et les contraintes.
4. Soumettre le formulaire.

Résultat attendu :

- Alcide génère un programme multi-semaines ;
- le programme peut être consulté depuis la liste des programmes ;
- chaque semaine ou séance peut être consultée dans le détail.

5. Consulter ses séances

1. Aller sur /workouts.
2. Lire les cartes de séances disponibles.
3. Utiliser les filtres par sport ou niveau si nécessaire.
4. Ouvrir une séance pour voir le détail.

La liste affiche uniquement les séances de l'utilisateur connecté.

6. Utiliser le timer

1. Ouvrir le détail d'une séance.
2. Cliquer sur Démarrer.
3. Suivre l'exercice affiché.
4. Utiliser Pause ou Reprendre si nécessaire.
5. Laisser le timer passer automatiquement aux phases suivantes.

Le timer annonce les changements d'état de façon accessible grâce aux zones dynamiques prévues dans l'interface.

7. Terminer et journaliser une séance

Lorsqu'une séance ou session est terminée, l'utilisateur peut renseigner son ressenti lorsque le formulaire est disponible :

- effort perçu ;
- feedback de difficulté ;
- notes de douleur éventuelles ;
- commentaire éventuel.

Ces informations alimentent les statistiques du dashboard.

Les notes de douleur ne constituent pas un diagnostic médical. Elles sont associées au compte connecté et doivent être considérées comme des données personnelles potentiellement sensibles. Consulter la page Confidentialité avant de les renseigner.

8. Consulter le dashboard

1. Cliquer sur Dashboard.
2. Lire les indicateurs principaux :

- séances créées ; - séances terminées ; - temps réalisé ; - effort moyen ; - dernière séance terminée ; - répartition par niveau ; - sports les plus pratiqués.

Si aucune séance n'existe, le dashboard propose de commencer par une première génération.

9. Paramétrer l'IA

La page de paramètres permet uniquement de choisir un modèle OpenAI parmi les modèles proposés. OpenAI est le fournisseur de l'application et la clé API est gérée par l'exploitant côté serveur. L'utilisateur ne peut ni saisir une clé, ni choisir un autre fournisseur.

Si la lecture ou l'enregistrement des paramètres échoue, l'interface affiche une erreur ; elle ne doit pas présenter une valeur de secours comme si elle avait été enregistrée.

10. Supprimer une séance

1. Depuis la liste des séances, cliquer sur l'action de suppression.
2. Confirmer la suppression.
3. Vérifier que la liste est mise à jour.

Si l'utilisateur annule la confirmation, la séance est conservée.

11. Accessibilité utilisateur

L'application prévoit :

- navigation clavier ;
- focus visible ;
- labels de formulaire ;
- messages d'erreur associés aux champs ;
- états de chargement ;
- informations dynamiques pour le timer.

Pour vérifier l'accessibilité en démonstration, utiliser la touche Tab pour parcourir l'interface et contrôler que chaque action reste atteignable.

Le reflow a été contre-recetté en production avec un zoom Chromium natif à 200 % et 400 % sur huit routes, soit 16 contrôles réussis sur 16. Cette preuve ne remplace pas une revue humaine exhaustive des fonds composites ni un parcours avec un lecteur d'écran réel.

12. Problèmes courants

Problème	Cause possible	Action utilisateur
Redirection vers login	Session absente ou expirée	Se reconnecter
Génération impossible	IA indisponible, clé absente ou quota atteint	Réessayer plus tard ou vérifier les paramètres
Aucun résultat dans la liste	Aucun entraînement créé ou filtre trop restrictif	Réinitialiser les filtres ou générer une séance
Dashboard vide	Aucune séance créée ou terminée	Générer puis exécuter une séance
Accès refusé à une séance	Séance inexistante ou appartenant à un autre utilisateur	Revenir à la liste personnelle

13. Parcours de démonstration recommandé

1. Se connecter.
2. Générer une séance courte.
3. Ouvrir le détail.
4. Démarrer le timer.
5. Revenir à la liste.
6. Filtrer les séances.
7. Ouvrir le dashboard.
8. Montrer la déconnexion.

DOC-03 - Manuel de mise à jour complet

1. Objectif

Ce manuel décrit la procédure de mise à jour d'Alcide pour livrer une nouvelle version applicative sans casser les parcours existants.

Il couvre :

- mise à jour du code ;
- mise à jour des dépendances ;
- migrations de base de données ;
- tests de non-régression ;
- déploiement ;
- vérification post-déploiement ;
- rollback.

2. Préconditions

Avant toute mise à jour :

- travailler sur une branche dédiée ;
- vérifier l'état Git avec `git status --short --branch` ;
- vérifier la version actuelle dans `package.json` ;
- récupérer les dernières modifications avec `git fetch --prune origin` puis `git pull --ff-only origin main` si la branche est `main` ;
- ne jamais modifier une variable secrète réelle dans le dépôt.

3. Mise à jour du code applicatif

1. Créer ou utiliser une branche de travail.
2. Modifier uniquement le périmètre nécessaire.
3. Mettre à jour les tests si le comportement change.
4. Mettre à jour la documentation RNCP si la preuve associée change.
5. Relire le diff :

```
git diff --stat
git diff
```

Critère de validation :

- le diff est cohérent avec l'objectif ;
- aucune modification hors périmètre n'est présente ;
- les preuves RNCP restent alignées avec le code réel.

4. Mise à jour des dépendances

1. Identifier les dépendances à mettre à jour.
2. Lire le changelog des dépendances majeures.
3. Mettre à jour `package.json` ou utiliser l'outil `package manager`.
4. Régénérer le lockfile avec `pnpm`.
5. Lancer les contrôles :

```
pnpm install --frozen-lockfile
pnpm lint
```

```
pnpm typecheck
pnpm test
pnpm test:coverage
pnpm build
pnpm audit --audit-level=low
```

Critère de validation :

- le lockfile est cohérent ;
- aucun test critique ne régresse ;
- aucune vulnérabilité connue à partir du niveau low n'est laissée sans correction ou justification explicite.

5. Migration de base de données

Lorsqu'un changement touche `apps/api/src/db/schema.ts` :

1. Générer la migration :

```
pnpm db:generate
```

2. Relire le fichier de migration généré.
3. Vérifier que la migration est compatible avec les données existantes.
4. Appliquer la migration sur l'environnement cible :

```
pnpm db:migrate
```

5. Vérifier les fonctionnalités concernées.

Critères de prudence :

- éviter les suppressions destructrices non justifiées ;
- prévoir une sauvegarde avant production ;
- documenter tout changement irréversible.

6. Tests de non-régression

Commandes minimales avant livraison :

```
pnpm lint
pnpm typecheck
pnpm test
pnpm test:coverage
pnpm build
```

Commandes recommandées avant dépôt RNCP ou livraison importante :

```
pnpm test:e2e:smoke
$env:E2E_AUTH_EMAIL='adresse-du-compte-dedie@example.com'
$env:E2E_BASE_URL='https://ai-sport-web.vercel.app'
pnpm test:e2e:auth:browser
## Après la connexion Google et le retour sur /generate :
pnpm test:e2e:auth:capture
pnpm test:e2e:authenticated
```

`test:e2e:smoke` couvre le public. La commande authentifiée exige un `storageState Auth.js` réel, local, non committé. La procédure sécurisée complète est décrite dans `docs/testing-authenticated-e2e.md`. `pnpm test:e2e` seul marque la suite authentifiée ignorée si cette variable manque ; il ne prouve donc pas le parcours OAuth. Si les E2E ne sont pas relancés, la documentation doit conserver le statut "à relancer" au lieu d'annoncer une réussite.

7. Mise à jour de version

Pour une version applicative :

1. Mettre à jour la version dans :
 - `package.json` ; - `apps/api/package.json` ; - `apps/web/package.json`.
2. Vérifier les fallback de healthcheck :

- apps/api/src/routes/health.routes.ts ; - apps/web/app/api/health/route.ts.

3. Mettre à jour CHANGELOG.md.

4. Vérifier que docs/deployment.md et les documents RNCP ne mentionnent pas une version contradictoire.

Contrôle :

```
rg -n "0\\.12\\.0|version applicative|APP_VERSION|NEXT_PUBLIC_APP_VERSION" package.json apps docs README.md CHANGELOG.md
```

Adapter la recherche selon la nouvelle version.

8. Déploiement

Le déploiement se fait via les workflows et la cible Vercel/Neon documentée.

Contrôles avant déploiement :

- CI verte ;
- migrations prêtes ou non nécessaires ;
- variables d'environnement présentes ;
- build local ou CI réussi ;
- changelog mis à jour.

Contrôles après déploiement :

```
curl https://<api-url>/health
curl https://<api-url>/health/ready
curl https://<web-url>/api/health
```

Puis vérifier manuellement :

1. page d'accueil ;
2. login ;
3. génération ou consultation avec données seedées ;
4. liste des séances ;
5. détail et timer ;
6. dashboard.

9. Rollback

Rollback applicatif :

1. Identifier la dernière version stable dans Vercel ou Git.
2. Revenir au déploiement précédent.
3. Vérifier les healthchecks.
4. Relancer un smoke test.
5. Documenter l'incident ou l'écart dans le plan de correction.

Rollback base de données :

- privilégier une sauvegarde/restauration lorsque la migration est destructive ;
- éviter de lancer une migration inverse non testée ;
- consigner précisément le changement de schéma et l'impact utilisateur.

10. Traçabilité

Après une mise à jour, documenter :

- version livrée ;
- fichiers principaux modifiés ;
- commandes lancées ;
- résultat des tests ;
- migration ou non ;
- statut du déploiement ;
- anomalies détectées ;
- action de rollback si nécessaire.

Documents à mettre à jour si concernés :

- CHANGELOG.md
- docs/deployment.md
- docs/ci-cd.md
- docs/bloc2/cahier-recettes.md
- docs/rncp/dossier-professionnel-rncp39583.md
- docs/rncp/matrice-conformite-rncp39583.md